

AI vs. Cyber Threats: Measuring Insights, Accuracy, and Actionability in CVE Analysis



Authors: Anh Ha, Tony Nguyen, Isabel Tilles

Advisor: Dr. Jay Yang

Acknowledgements: Reza Fayyazi

Research Question

How do LLM models perform when querying outside of their knowledge base?

What makes a good response?

- **Insightfulness:** How detailed or useful are the responses?
- **Verifiability:** Can reputable sources confirm the information?
- **Relevance:** Does the output answer all aspects of the prompt?
- **Hallucination:** Does the response invent facts, sources, or details?

Methodology

- **CVE:** *Common Vulnerabilities and Exposures*
 - A standardized framework for cybersecurity professionals to discuss vulnerabilities.
- **Experiment Setup:**
 - Use CVE IDs from **2020-21** (known in model training) and **2024-25** (unknown in foundational knowledge).
 - Compare outputs from **3 models** using a **standardized prompts** and **CVE IDs**.
 - Model 0.0: GPT-4.1-mini.
 - Model 1.0: GPT-4.1-mini with the built-in web search feature.
 - Model 1.5: GPT-4.1-mini with ProveRAG².

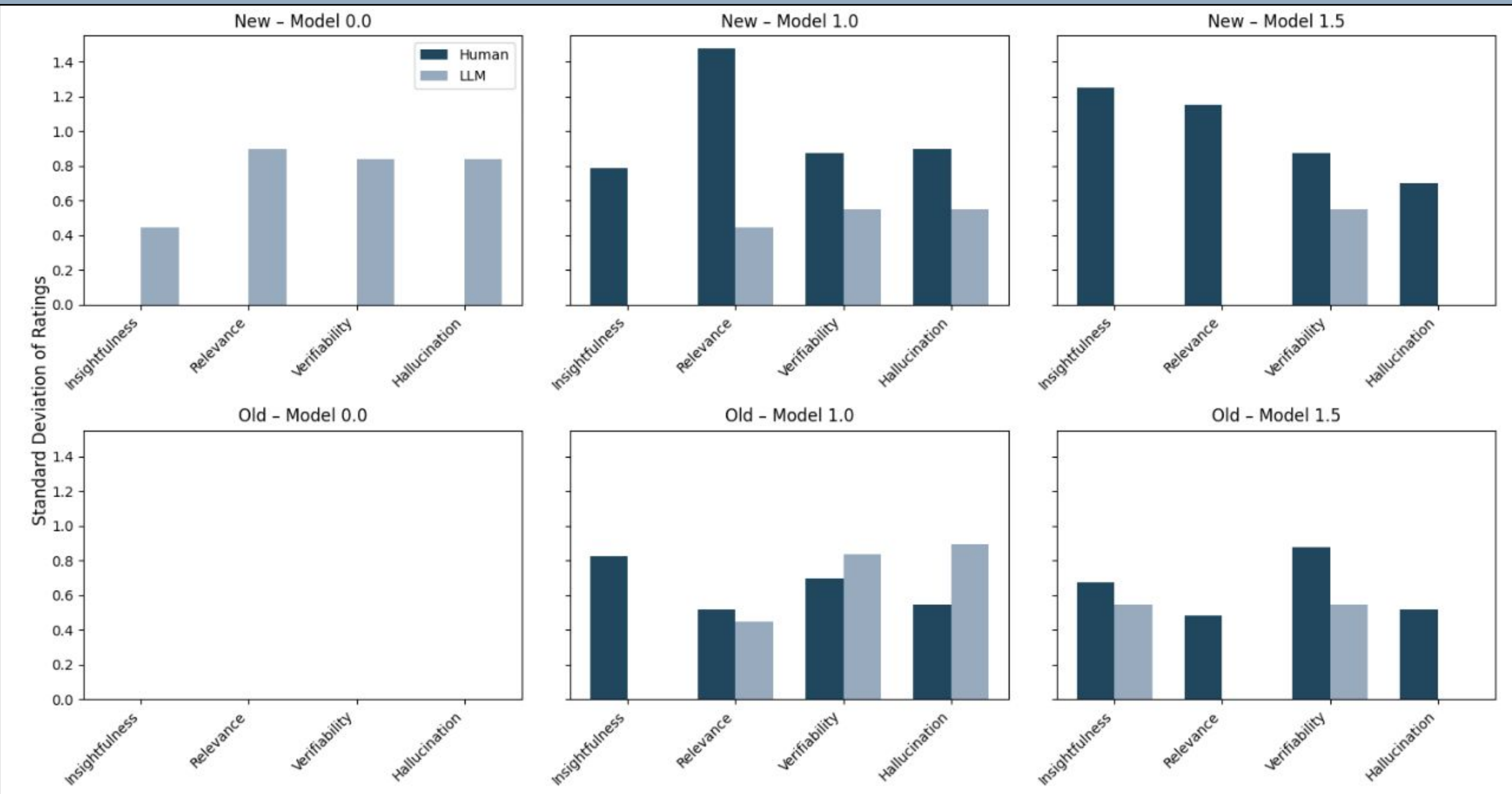
Why It Matters?

- **Pre-trained limitations:** GPT models lack real-time updates, leading to inaccurate advice, meaning increased security risks.
- **Trustworthiness:** Establishing a systematic way to measure AI reliability.
- **Human-AI collaboration:** Helping professionals focus on solutions rather than manual verification.

Implementation

- Using a predefined rubric on a scale of 1 to 5 and the CVE database as ground-truth:
 - **Self-evaluate:** Team members rate the responses manually.
 - **Using LLM-as-a-judge:** Use a LLM with a RAG pipeline that automatically fetches ground-truths and rates the responses.

Results



Takeaways

- **Unreliability of LLM judge:** The LLM rated the new CVEs of Model 0.0 with a high variance. In these instances, the model hallucinates what it deems to be the correct response, since the solutions are not publicly available yet. Therefore, variance in ratings indicate that the LLM judge hallucinates as well.
- **Importance of source selection:** When Model 1.0 queried the Internet, some sources retrieved were low-quality webpages, which caused the ratings to swing widely. When Model 1.5 searched with correct references, it resulted in a more consistent rating across CVEs.
- **Consistency between Human and LLM:** Human raters disagree over nuance, whereas the LLM is more internally consistent because it scores on fact-match. However, we have seen that its performance is not reliable for newer CVEs. This is where Human raters are needed for more subtle insights.

Sources

1. "Overview." CVE, <https://www.cve.org/about/overview>.
2. Fayyazi, Reza, et al. *ProveRAG: Provenance-Driven Vulnerability Analysis with Automated Retrieval-Augmented LLMs*. arXiv, 5 Feb. 2025, <https://arxiv.org/abs/2410.17406v2>.
3. Ip, Jeffrey. "LLM Evaluation Metrics: The Ultimate LLM Evaluation Guide." *Confident AI*, 7 Nov. 2024, <https://www.confident-ai.com/blog/llm-evaluation-metrics-everything-you-need-for-llm-evaluation>.